CHECKOUT GUARDIAN

Software Requirements Specification (SRS) — Version 1.0

Project: Checkout Guardian

Standard: IEEE 29148-Aligned SRS

Status: Approved / Implementation-Ready

Date: October 2026

Table of Contents

1. Introduction
2. Overall System Description
3. User Classes and Characteristics
4. System Features and Functional Requirements
5. External Interface Requirements
6. Detailed Input and Output Specifications
7. Data Requirements
8. Business Rules
9. Non-Functional Requirements
10. System States and State Transitions
11. Exception and Error Handling Requirements
12. Security and Privacy Requirements
13. Verification and Validation Requirements
14. Acceptance Criteria
15. Requirements Traceability Matrix
16. Assumptions, Dependencies and Open Issues

1. Introduction

Purpose: This Software Requirements Specification (SRS) defines the complete functional, non-functional, and interface requirements for Checkout Guardian, developed for the PayPal AI Hackathon 2026.

Scope: Checkout Guardian provides real-time e-commerce fraud detection, merchant identity verification, and pre-payment transaction intervention.

Core Innovation: The Merchant Identity & Offer Consistency Engine, which reconciles storefront brand claims against actual PayPal payment recipients.

2. Overall System Description

The system operates as an integrated security layer combining client-side DOM inspection, backend heuristic and LLM analysis, and PayPal Sandbox order capture control to protect online shoppers from fraudulent merchants.

3. User Classes and Characteristics

- **Online Shopper:** Everyday consumer browsing retail websites; receives automated safety ratings and risk warnings.
- **High-Risk Purchaser:** Consumer purchasing unfamiliar or high-ticket items requiring heightened transaction scrutiny.
- **System Administrator:** Manages audit logs, system thresholds, and API configurations.
- **Integrated Merchant:** E-commerce storefront application embedding the Checkout Guardian SDK and payment capture controls.

4. System Features and Functional Requirements

ID	Requirement Description	Priority
FR-001	The system shall ingest and validate target shopping URLs within 500ms of page load.	Must Have
FR-002	The system shall perform WHOIS domain age and SSL certificate verification.	Must Have

FR-003	The system shall extract claimed business names and cross-reference entity credentials.	Must Have
FR-004	The system shall compare advertised product pricing against baseline reference norms.	Should Have
FR-005	The Merchant Identity & Offer Consistency Engine shall compare store brand claims against actual PayPal `PAYEE_MERCHANT_ID`.	Must Have
FR-006	The AI analysis module shall return structured JSON evidence without independently authorizing payment capture.	Must Have
FR-007	The Risk Assessment Engine shall synthesize signals into LOW, MEDIUM, or HIGH risk tiers.	Must Have
FR-008	The backend shall validate risk decisions and pause payment capture in PayPal Sandbox upon high-risk triggers.	Must Have

5. External Interface Requirements

Defines interactions between the React frontend, Chrome Extension content scripts, Express REST APIs, PostgreSQL database, and PayPal Sandbox SDK endpoints over secure TLS 1.3 channels.

6. Detailed Input and Output Specifications

All API requests and responses enforce strict JSON schemas. For example, risk assessment outputs structured payloads containing scores, tiers, and natural-language explanatory evidence.

```
{
  "assessmentId": "risk_554433",
  "riskScore": 88,
  "riskTier": "HIGH",
  "action": "PAUSE_CAPTURE",
  "explanations": ["Merchant identity mismatch detected."]
}
```

7. Data Requirements

Database schema comprises relational tables for users, websites, merchants, assessments, risk indicators, transactions, and audit logs with strict data minimization and zero raw PII storage.

8. Business Rules

- **BR-001:** URLs must undergo validation before analysis execution.
- **BR-005:** The LLM must never independently authorize payment capture.
- **BR-006:** The integrated backend must validate risk decisions before executing PayPal capture.
- **BR-009:** Unavailable external verification data must be treated as unknown rather than fraudulent.

9. Non-Functional Requirements

Category	Requirement Target
Performance	End-to-end risk evaluation latency < 2.0 seconds.
Security	TLS 1.3 encryption, environment-secured credentials, zero client-side secret exposure.
Reliability	99.9% uptime target with graceful fail-open degradation during transient API timeouts.

10. System States and State Transitions

Lifecycle transitions manage Website Analysis States (Pending $\rightarrow$ Completed), Risk Assessment States (Low/Medium/High Risk), and Payment States (Order Created $\rightarrow$ Risk Assessment Pending $\rightarrow$ Captured / Blocked).

11. Exception and Error Handling Requirements

Transient API timeouts or unreachable domains invoke fallback mechanisms, logging warnings and assigning neutral scores to prevent false-positive blocking.

12. Security and Privacy Requirements

Enforces strict input sanitization, parameterized queries against SQL injection, secure environment variable management for API keys, and comprehensive audit logging.

13. Verification and Validation Requirements

Validated via Jest unit tests, Supertest API integration tests, and live end-to-end scenario testing across genuine, suspicious, and fraudulent merchant test cases.

14. Acceptance Criteria

Successful demonstration of automated website metadata ingestion, merchant consistency checking, risk scoring, and verified payment capture pausing within PayPal Sandbox.

15. Requirements Traceability Matrix

Maps all original proposal objectives and PRD/TRD specifications directly to SRS functional requirements and test case execution IDs.

16. Assumptions, Dependencies and Open Issues

Assumes sandbox API merchant identifiers simulate real production structures; external WHOIS and LLM API availability required for optimal performance.
